COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.3 · OS Vulnerabilities

Mestre CyberSec · **Lesson 2.3 — OS Vulnerabilities** (4:09) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Falha no sistema operacional (kernel, serviços, bibliotecas). Windows tem Patch Tuesday — dezenas de correções por mês. SO sem patch = alvo fácil. Zero-day OS = sem correção disponível. Defesa: patch ASAP, EDR.

💡 Key Exam Highlights & Critical Concepts

- Patch Tuesday: Microsoft corrige dezenas de CVE por mês
- Legacy (XP): sem suporte, sem patch — desativar/segmentar

🎯 Exam Tips & Typical CompTIA Scenarios

- 'operating system lacks patches' = legacy/unsupported OS vulnerability

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.3 — OS Vulnerabilities)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Patch Tuesday

Microsoft's monthly security update release, occurring on the second Tuesday of each month, typically fixing dozens of CVEs across Windows and related software. An unpatched OS between cycles is an easy exploitation target.

⚠ ***Exam Trap:*** *Trigger: 'second Tuesday of the month' or 'dozens of monthly Microsoft fixes' = Patch Tuesday. Key distinction: Patch Tuesday = scheduled release cycle; out-of-band/emergency patch = critical fix released at any time outside the cycle.*

• Zero-Day Vulnerability

A vulnerability unknown to the vendor or publicly disclosed with no patch available, leaving defenders zero days to react. OS zero-days are severe because exploitation targets the kernel and all services running on it.

⚠ ***Exam Trap:*** *Trap: zero-day = NO patch exists; 'unpatched/missing patches' = patch exists but was not applied. If the stem says 'no fix is available', answer zero-day, not legacy OS.*

• Legacy Operating System

An older OS that no longer receives vendor security patches (e.g., Windows XP), remaining permanently vulnerable to known exploits. Mitigation requires replacement or, if replacement is impossible, network isolation.

⚠ ***Exam Trap:*** *Direct exam trigger from this lesson: 'operating system lacks patches' = legacy/unsupported OS vulnerability. Mitigation order: upgrade/replace first → segment/isolate if it cannot be replaced. Don't pick 'install antivirus' as the full answer.*

• End-of-Life (EOL)

The vendor-declared date after which a product stops receiving all updates and support entirely; EOL software must be decommissioned or tightly segmented because it will never be patched again.

⚠ ***Exam Trap:*** *Distinction: EOL = vendor permanently stopped support; 'not yet patched' = updates exist but are pending. EOL device in a question → segment or replace, and treat it as unfixable.*

• Endpoint Detection and Response (EDR)

A solution that continuously monitors endpoints, detecting and responding to suspicious process and behavior-based activity on operating systems — the key compensating control when patching is delayed or impossible.

⚠️ ***Exam Trap:*** *Distinction: EDR = behavioral detection with response actions (isolate host, remove threat); signature-based anti-malware = known threats only. Expect EDR paired with zero-day or legacy OS scenarios in this lesson.*

• Common Vulnerabilities and Exposures (CVE)

A MITRE-maintained catalog using the CVE-YYYY-NNNN format that uniquely identifies publicly disclosed vulnerabilities; vendor advisories and Patch Tuesday releases reference these IDs.

⚠️ ***Exam Trap:*** *Distinction: CVE names/identifies the vulnerability; CVSS (0.0–10.0) scores its severity; NVD is the searchable database of CVEs. Don't swap CVE and CVSS in an answer.*

• Segmentation

A network architecture control that isolates unpatchable or legacy systems into restricted segments enforced by firewalls/ACLs, containing an OS compromise so it cannot spread laterally.

⚠️ ***Exam Trap:*** *Exam pairing: legacy/EOL OS that 'cannot be replaced' → segmentation or isolation is the best available control. Distinction: segmentation = logical isolation with rules; air gap = full physical separation.*

• Kernel

The core component of an operating system that manages memory, processes, and hardware access; a kernel vulnerability compromises the entire system because every service and library depends on it.

⚠️ ***Exam Trap:*** *Hierarchy from this lesson: kernel (core) → services → shared libraries — a flaw in any layer = OS vulnerability. Kernel-level compromise means the highest impact, typically root/system privileges.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company has a large fleet of Windows workstations and servers. The IT director wants a predictable monthly maintenance window for Microsoft operating system security updates while still allowing a short testing period before production deployment. Which patch management practice best meets this requirement?

A) Apply Microsoft OS security updates on the second Tuesday of each month after validating them in a test group.

B) Apply OS updates only when a new CVE is published for the operating system.

C) Allow users to postpone all OS updates indefinitely until they report performance problems.

D) Patch only systems that have already shown signs of compromise.

QUESTION 2 · EXAM SCENARIO

Threat intelligence reports that a zero-day vulnerability in the operating system kernel is being actively exploited. No vendor patch is available yet. Which action should the security team take first?

A) Wait for the next scheduled Patch Tuesday and rely on existing antivirus signatures until then.

B) Disable the affected kernel module on all systems, including business-critical ones, without testing.

C) Enable EDR behavioral detection and deploy compensating controls such as hardening and network restrictions.

D) Reimage every endpoint in the organization immediately, including unaffected systems.

QUESTION 3 · EXAM SCENARIO

A manufacturing plant uses an unsupported legacy OS on a controller because the vendor software is not certified for newer platforms. The controller must communicate only with a specific engineering workstation. Which control best reduces the risk of lateral movement from the corporate network?

A) Join the controller to the corporate Active Directory domain for centralized authentication.

B) Place the controller in a separate network segment with firewall rules permitting only required traffic to the engineering workstation.

C) Assign the controller a public IP address so the vendor can support it remotely without VPN.

D) Install a modern EDR agent even though the legacy OS does not support it.

QUESTION 4 · EXAM SCENARIO

An organization's asset inventory identifies several Windows Server 2008 R2 systems that no longer receive security updates from Microsoft. The business application on them has no supported upgrade path yet, but it is critical. Which risk treatment is most appropriate initially?

A) Continue applying the latest Windows security updates manually from Microsoft Update.

B) Rely on the host firewall as the permanent control and take no further action.

C) Keep the servers running as-is and rely on yearly vulnerability scans to identify issues.

D) Isolate and monitor the servers while planning migration or replacement with a supported OS.

QUESTION 5 · EXAM SCENARIO

A vulnerability scanner reports an issue in an OS library. The analyst needs to correlate the finding with vendor advisories, scanner databases, and threat intelligence feeds. Which standardized identifier should the analyst use for this correlation?

A) CVSS

B) CVE

C) CWE

D) MITRE ATT&CK

QUESTION 6 · EXAM SCENARIO

During an incident response engagement, analysts determine that an attacker exploited a vulnerability in the operating system kernel of a Linux server. The attacker started with a low-privileged web service account and then obtained full control of the operating system. Which impact has occurred?

A) Denial of service

B) Session hijacking

C) Privilege escalation

D) Data loss due to hardware failure

QUESTION 7 · EXAM SCENARIO

A fileless malware sample exploits a newly disclosed OS service vulnerability. Traditional signature-based antivirus does not detect the activity because no known file signature exists. Which control is best suited to detect and respond to the malicious behavior on endpoints?

A) Full disk encryption

B) Data loss prevention

C) Network access control

D) Endpoint Detection and Response

QUESTION 8 · EXAM SCENARIO

A vendor releases an emergency fix for a critical remotely exploitable vulnerability in an OS service. The next monthly patch cycle is three weeks away, and the vulnerability is being actively exploited. What should the patch management team do?

A) Wait for the monthly patch cycle to minimize operational disruption.

B) Use emergency change procedures to test and deploy the patch as rapidly as possible, prioritizing exposed systems.

C) Deploy the patch to every system immediately without testing or rollback planning.

D) Apply the patch only to non-critical systems and leave critical servers unpatched until the monthly cycle.

QUESTION 9 · EXAM SCENARIO

A critical vulnerability is announced in an OS service. The vendor patch cannot be deployed for 48 hours because compatibility testing is required. The service is enabled by default, but most servers do not need it. Which compensating control best reduces immediate risk?

A) Disable the vulnerable service where it is not required and restrict it with firewall rules where it is required.

B) Rely on existing antivirus signatures and continue normal operations until the patch is available.

C) Change all local administrator passwords and continue normal operations.

D) Deploy a host-based intrusion prevention system but leave the service enabled on all servers.

QUESTION 10 · EXAM SCENARIO

A vulnerability scan shows many missing OS patches. One finding is a kernel vulnerability on internet-facing VPN servers that is listed as known exploited. The remaining findings are local privilege escalation issues on internal workstations with low likelihood. Which remediation approach is most appropriate?

A) Patch systems in alphabetical order to ensure consistent progress.

B) Delay all patching until the annual maintenance window to reduce change risk.

C) Prioritize the known exploited kernel vulnerability on the internet-facing VPN servers and apply compensating controls until patched.

D) Patch only the internal workstations because there are more of them.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Apply Microsoft OS security updates on the second Tuesday of each month after validating them in a test group.

Microsoft releases most Windows security updates on Patch Tuesday, the second Tuesday of each month. A controlled monthly cycle with testing balances predictability and risk reduction. Waiting for CVE publication, indefinite user deferral, or patching only compromised systems leaves known vulnerabilities exploitable.

Question 2: Option C — Enable EDR behavioral detection and deploy compensating controls such as hardening and network restrictions.

No vendor patch is available for a zero-day, so compensating controls and behavioral detection are appropriate. EDR can identify exploit behavior and block or contain threats. Waiting leaves systems exposed; disabling a kernel module without testing can cause outages; reimaging all systems is disruptive and not targeted.

Question 3: Option B — Place the controller in a separate network segment with firewall rules permitting only required traffic to the engineering workstation.

Segmentation limits lateral movement by restricting which systems can communicate with the legacy OS. A dedicated VLAN and least-permission firewall rules reduce exposure. Joining it to the corporate domain expands attack surface; a public IP exposes it; unsupported EDR cannot be installed or relied upon.

Question 4: Option D — Isolate and monitor the servers while planning migration or replacement with a supported OS.

An end-of-life OS no longer receives vendor security patches, so the long-term fix is migration or replacement. In the interim, isolation and enhanced monitoring reduce exposure. Continuing updates is not possible; a host firewall alone is insufficient; yearly scans do not replace timely remediation.

Question 5: Option B — CVE

CVE provides a unique identifier for a specific publicly known vulnerability, enabling correlation across scanners, vendor advisories, and threat intelligence. CVSS is a severity score, CWE classifies weakness types, and MITRE ATT&CK describes adversary tactics and techniques.

Question 6: Option C — Privilege escalation

Kernel vulnerabilities can allow attackers to cross privilege boundaries and gain root/SYSTEM-level control. Moving from a low-privileged account to full OS control is privilege escalation. DoS, session hijacking, or hardware failure are different impact categories.

Question 7: Option D — Endpoint Detection and Response

EDR collects endpoint telemetry and uses behavioral analytics to detect suspicious process, memory, and system activity, including fileless and zero-day exploits. DLP focuses on data exfiltration, NAC controls network admission, and full disk encryption protects data at rest.

Question 8: Option B — Use emergency change procedures to test and deploy the patch as rapidly as possible, prioritizing exposed systems.

Emergency out-of-band patches are warranted for critical, actively exploited vulnerabilities. An emergency change process should include expedited testing, rollback planning, and prioritization of internet-facing or high-value systems. Waiting increases exposure; deploying without any testing or rollback is risky; leaving critical systems unpatched is inappropriate.

Question 9: Option A — Disable the vulnerable service where it is not required and restrict it with firewall rules where it is required.

Reducing the attack surface by disabling unnecessary services and restricting required access limits exploitation opportunities until patching is possible. Relying only on antivirus does not fix the flaw; changing passwords alone does not fix the service; leaving the service enabled on all servers maintains unnecessary exposure.

Question 10: Option C — Prioritize the known exploited kernel vulnerability on the internet-facing VPN servers and apply compensating controls until patched.

Risk-based patching prioritizes vulnerabilities based on exploitability, exposure, and impact. A known exploited kernel flaw on internet-facing systems represents the highest immediate risk. Alphabetical order, annual delays, or patching by count ignore risk.